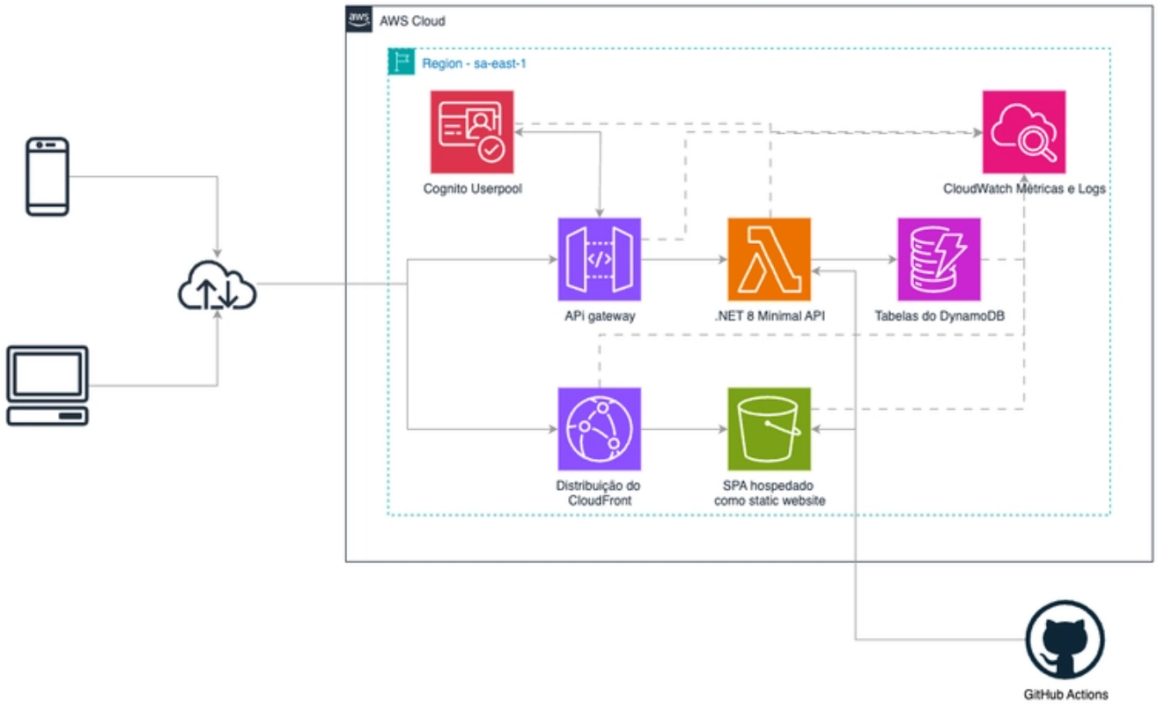
Relatório de Avaliação de Ameaças STRIDE

Data: 20/12/2024 às 14:30 **Classificação:** Uso Interno



Sumário Executivo

A arquitetura analisada compreende 10 componentes AWS formando uma aplicação serverless com frontend distribuído. Foram identificadas 28 ameaças: 6 críticas, 9 altas, 8 médias e 5 baixas. Os principais riscos concentram-se na exposição de dados sensíveis no S3, configurações inadequadas de CORS no API Gateway, e autenticação insuficiente no Cognito. Recomenda-se implementação imediata de

criptografia no S3, revisão de políticas IAM e configuração adequada de WAF no CloudFront.

---

1. Arquitetura Analisada

A aplicação é composta pelos seguintes componentes:

#	Componente	Tipo	Função na Arquitetura
1	AWS Lambda	Função Serverless	Processamento de lógica de negócio e APIs backend
2	Amazon S3	Armazenamento de Objetos	Armazenamento de arquivos, logs e conteúdo estático
3	Amazon API Gateway	Gateway de APIs	Exposição e gerenciamento de endpoints REST/HTTP
4	Amazon CloudFront	CDN	Distribuição de conteúdo e cache global
5	Amazon CloudWatch	Observabilidade	Monitoramento, logs e métricas da aplicação
6	AWS Backup	Backup e Recuperação	Backup automatizado de recursos AWS
7	Amazon Cognito	Autenticação e Autorização	Gerenciamento de identidades e controle de acesso
8	Amazon DynamoDB	Banco NoSQL	Armazenamento de dados da aplicação
9	Client Desktop	Cliente Web	Interface de usuário para acesso via navegador
10	Mobile Client	Cliente Móvel	Aplicativo móvel para acesso via dispositivos

---

2. Análise de Ameaças STRIDE

Legenda STRIDE

- **S** - Spoofing (Falsificação de Identidade)
- **T** - Tampering (Adulteração de Dados)
- **R** - Repudiation (Repúdio)
- **I** - Information Disclosure (Vazamento de Informação)
- **D** - Denial of Service (Negação de Serviço)
- **E** - Elevation of Privilege (Elevação de Privilégio)

Matriz de Ameaças

ID	Componente	STRIDE	Cenário de Ameaça	Impacto	Mitigação Recomendada	Prioridade
T001	AWS Lambda	E	Execução de código malicioso via payloads em variáveis de ambiente ou dependências vulneráveis	Comprometimento completo da função e acesso a recursos conectados	Implementar AWS Lambda Layers para dependências, scanning de vulnerabilidades com Amazon Inspector	Crítica
T002	AWS Lambda	I	Vazamento de credenciais ou informações sensíveis através de logs do CloudWatch	Exposição de tokens, chaves API e dados de configuração	Configurar log filtering, usar AWS Secrets Manager para credenciais	Alta
T003	AWS Lambda	D	Esgotamento de concurrent executions causando indisponibilidade do serviço	Aplicação indisponível para todos os usuários	Configurar reserved concurrency e dead letter queues	Média

ID	Componente	STRIDE	Cenário de Ameaça	Impacto	Mitigação Recomendada	Prioridade
T004	Amazon S3	I	Exposição de buckets com permissões públicas inadvertidas	Vazamento massivo de dados sensíveis da aplicação	Implementar S3 Block Public Access, S3 Bucket Notifications e AWS Config rules	Crítica
T005	Amazon S3	T	Modificação de objetos por usuários com permissões inadequadas	Corrupção de dados críticos da aplicação	Habilitar S3 Object Versioning, MFA Delete e S3 Object Lock	Alta
T006	Amazon S3	D	Deletion massiva de objetos por ator malicioso com acesso	Perda total de dados armazenados	Configurar S3 Cross-Region Replication e lifecycle policies para transição para Glacier	Média
T007	API Gateway	S	Bypass de autenticação através de manipulação de headers ou tokens	Acesso não autorizado a recursos protegidos	Implementar AWS WAF com rate limiting, validação rigorosa de tokens JWT	Alta
T008	API Gateway	I	Exposição de informações sensíveis através de error messages detalhados	Revelação de estrutura interna da aplicação	Configurar custom error responses e logging structured	Média
T009	API Gateway	D	Ataques de flooding e rate limiting bypass	Indisponibilidade da API para usuários legítimos	Configurar throttling policies por API	Alta

ID	Componente	STRIDE	Cenário de Ameaça	Impacto	Mitigação Recomendada	Prioridade
					key e usage plans	
T010	CloudFront	T	Cache poisoning através de headers maliciosos	Entrega de conteúdo modificado para usuários finais	Configurar cache behaviors específicos e Origin Access Control	Alta
T011	CloudFront	D	DDoS amplification attacks utilizando edge locations	Sobrecarga da infraestrutura de origem	Habilitar AWS Shield Advanced e configurar AWS WAF	Média
T012	CloudFront	I	Vazamento de origem real através de direct access bypass	Exposição de endereços IP e recursos internos	Configurar Security Groups restritivos e Origin Access Identity	Baixa
T013	CloudWatch	R	Ausência de logs críticos para auditoria de segurança	Impossibilidade de rastreamento de incidentes	Implementar AWS CloudTrail e structured logging com correlation IDs	Média
T014	CloudWatch	I	Acesso não autorizado a logs contendo informações sensíveis	Exposição de dados pessoais e credenciais	Configurar log groups encryption e IAM policies granulares	Alta
T015	CloudWatch	D	Esgotamento de storage por log flooding	Indisponibilidade de monitoramento e alertas	Configurar log retention policies e CloudWatch Logs Insights	Baixa

ID	Componente	STRIDE	Cenário de Ameaça	Impacto	Mitigação Recomendada	Prioridade
T016	AWS Backup	T	Modificação ou corrupção de backups por acesso privilegiado	Perda de capacidade de recuperação de desastres	Implementar cross-account backup e backup vault lock policies	Crítica
T017	AWS Backup	I	Vazamento de dados sensíveis através de backups não criptografados	Exposição de dados históricos da aplicação	Configurar encryption em trânsito e em repouso com AWS KMS	Alta
T018	AWS Backup	D	Falha na execução de backups por permissões inadequadas	Perda de dados em caso de falha do sistema	Configurar backup notifications e cross-region backup copy	Média
T019	Amazon Cognito	S	Falsificação de identidade através de user enumeration	Comprometimento de contas de usuário	Implementar CAPTCHA, account lockout policies e MFA obrigatório	Crítica
T020	Amazon Cognito	E	Escalação de privilégios através de group membership manipulation	Acesso a recursos administrativos não autorizados	Configurar fine-grained IAM roles e attribute-based access control	Crítica
T021	Amazon Cognito	R	Ausência de audit trail para mudanças de permissões	Impossibilidade de rastreamento de alterações de acesso	Integrar com CloudTrail e implementar change notifications	Média
T022	DynamoDB	I	Vazamento de dados através	Exposição de grandes volumes	Implementar query patterns	Alta

ID	Componente	STRIDE	Cenário de Ameaça	Impacto	Mitigação Recomendada	Prioridade
			de scan operations não otimizadas	de dados sensíveis	otimizados e DynamoDB encryption at rest	
T023	DynamoDB	T	Modificação não autorizada de dados por privilege escalation	Corrupção de dados críticos da aplicação	Configurar DynamoDB fine-grained access control e point-in-time recovery	Alta
T024	DynamoDB	D	Throttling por consumo excessivo de read/write capacity	Indisponibilidade da aplicação para leitura/escrita	Implementar DynamoDB Auto Scaling e DynamoDB Accelerator (DAX)	Baixa
T025	Client Desktop	S	Session hijacking através de XSS ou CSRF attacks	Comprometimento de sessões de usuário	Implementar Content Security Policy, SameSite cookies e CSRF tokens	Alta
T026	Client Desktop	I	Exposição de tokens de acesso em local storage	Comprometimento de credenciais de autenticação	Utilizar secure HTTP-only cookies e token refresh patterns	Crítica
T027	Mobile Client	S	Man-in-the-middle attacks em conexões não seguras	Interceptação de credenciais e dados sensíveis	Implementar certificate pinning e mTLS authentication	Média
T028	Mobile Client	I	Extração de secrets do	Exposição de chaves API e endpoints internos	Utilizar runtime application self-protection e	Baixa

ID	Componente	STRIDE	Cenário de Ameaça	Impacto	Mitigação Recomendada	Prioridade
			application bundle		code obfuscation	

---

3. Resumo por Prioridade

Ameaças Críticas (6)

T001, T004, T016, T019, T020, T026

Ameaças Altas (9)

T002, T005, T007, T009, T010, T014, T017, T022, T023, T025

Ameaças Médias (8)

T003, T006, T008, T011, T013, T018, T021, T027

Ameaças Baixas (5)

T012, T015, T024, T028

---

4. Recomendações Prioritárias

1. **Implementar S3 Block Public Access e criptografia (T004, T017)** - Previne vazamentos massivos de dados
2. **Configurar MFA obrigatório e policies rigorosas no Cognito (T019, T020)** - Protege contra comprometimento de identidades
3. **Utilizar AWS Secrets Manager e secure storage para tokens (T001, T026)** - Elimina exposição de credenciais
4. **Habilitar S3 Object Lock e cross-region replication (T005, T016)** - Garante integridade e disponibilidade de dados

5. **Implementar AWS WAF com rate limiting no API Gateway (T007, T009)** - Protege APIs contra ataques automatizados

---

5. Próximos Passos

1. **Ação imediata**: Auditoria completa de permissões S3 e implementação de Block Public Access em todos os buckets
2. **Ação de curto prazo**: Configuração de MFA obrigatório no Cognito e revisão de políticas IAM granulares
3. **Ação de médio prazo**: Implementação de monitoramento avançado com AWS Security Hub e automatização de resposta a incidentes

---

Relatório gerado automaticamente por ferramenta de análise STRIDE.